

Healthcare Security Posture Assessment

Capstone 1: Asset, Threat & Risk Analysis

Client	AITEE Community Health Center
Prepared By	Paul (D3) — Junior Cybersecurity Analyst
Engagement Type	Theoretical Security Posture Assessment
Scope	Asset, Threat, Vulnerability & Risk Analysis (no live systems tested)

Security boundary note: This assessment is based entirely on a fictional training scenario. No real host, healthcare system, or live network was scanned, probed, or tested at any point in this exercise.

Mission Summary

AITEE Community Health Center is a 50-person healthcare provider running patient registration software, an EHR system, staff laptops, a shared Wi-Fi network, corporate email, and a basic server environment, supported by a small internal IT team. This report evaluates what needs protecting, what could go wrong, where the current setup falls short, and what to fix first.

Current Security Audit Findings (Baseline)

Snapshot of the environment as observed at the start of this engagement — this is the starting point every finding below builds on.

#	Domain	Observed Vulnerability / Current State
1	Passwords	Employees use simple, easy-to-guess passwords and reuse credentials across personal and work accounts.
2	Authentication (MFA)	Multi-Factor Authentication is not enforced on critical systems or administrative accounts.
3	User Awareness	Employees have received no official cybersecurity awareness or phishing simulation training.
4	Patching & Updates	Operating systems, applications, and connected systems are updated irregularly.
5	Data Protection	Unencrypted sensitive medical data is stored electronically on shared network drives.
6	Backup Strategy	Backups are taken occasionally, but data restoration procedures are never tested.
7	Wireless Security	Staff, corporate laptops, and guest visitors share the same wireless network.
8	Access Control	Excessive access permissions — employees can access files beyond their job duties.

Task 1 — Asset Identification & CIA Triad

Five key assets, beyond the worked example (Patient Records), that the organization depends on and needs to protect.

Asset Name	Why Is It Important?	What Could Happen If Lost / Compromised?
Administrator & System Login Credentials	These accounts hold privileged access to the EHR, patient records, and financial systems — effectively the keys to the whole network.	Full system compromise, ransomware deployment, and a breach that spans every connected system at once.
Staff Laptops & Endpoints	Used daily to access the EHR, email, and internal systems, and they regularly leave the building with staff.	Becomes a malware entry point or a direct data leak if lost, stolen, or infected.
Corporate Wi-Fi Network	Connects every clinical device, staff system, and admin tool to internal resources.	Traffic interception and a foothold for attackers to move laterally into other systems.
Financial & Billing Systems	Handles patient payments, insurance claims, and payroll, including banking and card data.	Financial fraud, direct monetary loss, and regulatory penalties tied to exposed payment data.
Connected Medical Devices	Support patient diagnostics and monitoring, often on outdated firmware with weak built-in security.	Patient safety risk if tampered with, and an easy entry point due to poor device-level protection.

Task 2 — Threat Identification

Five realistic threats facing AITEE Health Center, beyond the worked example (Phishing Emails).

Threat Vector	What System / Asset Could It Affect?	Possible Impact / Consequence
Ransomware Attack	EHR servers, shared network drives, backup systems	Complete lockout of patient records, halted clinic operations, costly recovery, possible ransom demand.
Insider Threat (malicious or negligent staff)	Any system the employee has access to — worsened by excessive permissions	Unauthorized data access or leakage, accidental exposure of patient health information, sabotage.
Device Theft or Loss	Staff laptops and mobile devices carrying patient data	Direct data breach if the device is unencrypted, HIPAA violation, reputational damage.
Unauthorized Wireless Access	Shared Wi-Fi network (staff, corporate, and guest combined)	An attacker on the guest network pivots into internal systems; traffic can be intercepted.
Exploitation of Unpatched Systems	OS, EHR software, connected medical devices	Known vulnerabilities exploited for remote code execution or malware installation.

Task 3 — Vulnerability Identification

Five vulnerabilities pulled from the audit findings, beyond the worked example (Weak / Reused Passwords), each linked to the threat it enables.

Vulnerability (Weakness)	Related Threat Vector	Why Is It Dangerous?
No MFA on Critical / Admin Accounts	Account Compromise / Ransomware entry	One stolen password is enough to reach admin-level access — there's no second layer stopping it.
No Security Awareness or Phishing Training	Phishing / Social Engineering	Staff can't recognize malicious emails or links, so social engineering succeeds far more easily.
Irregular Patching of Systems & Devices	Exploitation of Unpatched Systems	Known, public vulnerabilities stay open long after fixes exist, giving attackers an easy way in.
Unencrypted Sensitive Data on Shared Drives	Insider Threat / Device Theft	Anyone who reaches the drive, staff overreach or breach, can read patient data directly with no protection layer.
Shared Wireless Network (staff, corporate, guest)	Unauthorized Wireless Access	Guest devices sit on the same network as clinical systems — one compromised guest device puts everything at risk.

Task 4 — Security Risk Definition

Five risk scenarios formed by combining the assets, threats, and vulnerabilities above (Asset + Threat + Vulnerability = Risk).

Identified Risk Scenario	Systems / Data Affected	Why Does It Matter? (Business Impact)
A phishing email tricks a staff member into giving up their password; with no MFA in place, the attacker logs straight into the EHR.	EHR, patient records, admin accounts	Breach of thousands of patient records, HIPAA fines, loss of patient trust.
An unencrypted staff laptop is stolen, exposing patient files stored locally or cached from shared drives.	Patient records, staff laptop	Reportable breach under HIPAA, legal costs, reputational damage.
A compromised device on the shared guest Wi-Fi pivots into the internal network and reaches the unencrypted shared drives.	Wi-Fi network, shared drives, patient data	Silent, hard-to-detect breach with potential for large-scale data exfiltration.
Ransomware exploits an unpatched server, encrypts the EHR and backup drives, and the untested backups fail to restore operations.	EHR server, backup systems	Total operational shutdown, disrupted patient care, ransom demand, revenue loss.
An employee with access beyond their job role leaks payroll or billing data, intentionally or by accident.	Financial/billing systems, payroll data	Broken employee trust, exposure to financial fraud, legal liability.

Task 5 — Risk Prioritization

The top 3 risks, ranked by likelihood and impact.

#	Top Risk Scenario	Likelihood	Impact	Priority
1	Phishing + no MFA leads to direct EHR compromise	High	High	CRITICAL
2	Ransomware via unpatched systems, worsened by untested backups	Medium-High	High	CRITICAL
3	Unencrypted shared-drive data exposed through device theft or network access	Medium	High	HIGH

Justification

These three get addressed first because they represent the easiest paths in and the widest damage once an attacker is inside. Phishing combined with no MFA is the most probable initial access route, since staff have never been trained to spot a malicious email and there's no second factor to stop a stolen password. Ransomware is the scenario most likely to bring the entire clinic to a standstill, and it's made worse by backups nobody has verified actually work. Unencrypted data on the shared drives means that once either of the first two risks happens, or a device is simply lost, there's no protection layer left between an intruder and patient records. Closing these three cuts off the most likely entry points and limits how far any single incident can spread.

Task 6 — Recommended Security Controls

Controls mapped to the risks identified above, categorized as Administrative, Technical, or Physical.

Identified Risk	Control Type	Recommended Control	How It Reduces Risk
Phishing + no MFA	Admin / Tech	Enforce MFA on all admin and clinical accounts; run mandatory phishing simulation training.	Blocks account takeover even if a password is phished, and trains staff to catch the email before it works.
Ransomware via unpatched systems	Tech / Admin	Formal patch management schedule (critical patches within 72 hours) plus regular backup restoration drills.	Shrinks the window attackers have to exploit known flaws, and confirms backups actually recover data when needed.
Unencrypted data on shared drives	Tech	Encrypt data at rest and enforce role-based access control on shared drives.	Even if someone reaches the drive, the data stays unreadable without the right keys and the right role.
Device theft or loss	Tech / Phys	Full-disk encryption on all laptops and mobile devices, with remote-wipe capability enabled.	A stolen or lost device becomes useless to whoever finds it, and can be wiped remotely if needed.
Shared Wi-Fi network	Tech	Segment guest Wi-Fi from the staff and clinical network using VLANs.	Isolates outside devices from internal systems entirely, so a compromised guest device can't reach patient data.

Task 7 — Executive Summary

Written for AITEE Community Health Center leadership.

The security posture assessment of AITEE Community Health Center identified several critical gaps across technical and administrative controls that leave patient data and daily operations exposed. Employees currently reuse weak passwords, Multi-Factor Authentication is not enforced on any critical system, and staff have never received formal cybersecurity or phishing awareness training. These gaps combine with irregular patching, unencrypted data on shared drives, and a single Wi-Fi network shared by staff and guests to create a wide and largely undefended attack surface.

The three risks that matter most right now are: an attacker phishing a staff password and walking straight into the EHR system with no MFA to stop them; a ransomware attack exploiting unpatched systems and locking the organization out of patient records, made worse by backups that have never actually been tested; and unencrypted patient data sitting on shared drives that anyone reaching the network, staff or intruder, can read without restriction.

To reduce these risks, management should prioritize three actions: enforce MFA across all administrative and clinical systems, put staff through real phishing simulation training, and separate the guest Wi-Fi from the clinical network. These moves close the most likely paths an attacker would use to reach patient data, and none of them require a major infrastructure overhaul. Addressing them now protects both patient trust and the organization's standing under HIPAA.

Word count: 223 words